

VULNERABILITY ASSESSMENT REPORT

Metasploitable Vulnerable Virtual Machine

Assessment Type	Vulnerability Assessment (VA)
Target	Metasploitable VM
Target IP	192.168.1.31
Environment	Controlled laboratory environment
Primary Tool	Nmap 7.98
Assessment Date	30 August 2026
Overall Risk	CRITICAL

1. Executive Summary

A vulnerability assessment was conducted against the Metasploitable virtual machine at 192.168.1.31 in a controlled laboratory environment. Nmap identified a large attack surface with numerous open network services and multiple known vulnerabilities. The most severe finding was the vsFTPD 2.3.4 backdoor vulnerability (CVE-2011-2523), which Nmap marked as VULNERABLE (Exploitable) and whose check reported root-level execution.

Additional findings included Java RMI remote-code-execution exposure, SSL POODLE, weak Diffie-Hellman/Logjam configurations, and potentially vulnerable web applications and forms.

2. Scope and Methodology

The assessment was limited to the identified laboratory target. The primary command used was:

```
nmap --script vuln 192.168.1.31
```

The assessment focused on host discovery, exposed ports/services, and vulnerability identification. This document is a Vulnerability Assessment report; exploitation was not required to establish the findings.

3. Identified Services

Port	Service	Assessment
21	FTP	Critical exposure
22	SSH	Exposed service
23	Telnet	High risk legacy protocol
25	SMTP	Exposed service
53	DNS	Exposed service
80	HTTP	High attack surface
111	RPC	Exposed service
139	NetBIOS	High attack surface
445	SMB	High attack surface
512/513/514	rexec/rlogin/rsh	High risk legacy protocols
1099	Java RMI	Critical exposure
1524	ingreslock	High exposure
2049	NFS	High exposure

Port	Service	Assessment
2121	FTP	High exposure
3306	MySQL	High exposure
5432	PostgreSQL	High exposure

4. Vulnerability Findings

VA-01 — vsFTPD 2.3.4 Backdoor

Severity: Critical | **CVE:** CVE-2011-2523 | **Port:** 21/tcp

Nmap identified a vsFTPD 2.3.4 backdoor and reported it as VULNERABLE (Exploitable). The check output included uid=0(root) gid=0(root), providing strong evidence of severe compromise potential.

Recommendation: Remove the affected version, replace it with a trusted supported release, disable FTP if unnecessary, restrict access, and investigate the host for unauthorized modification.

VA-02 — Java RMI Registry Remote Code Execution Exposure

Severity: Critical | **Port:** 1099/tcp

Nmap reported a vulnerable RMI registry default configuration that may allow loading classes from remote URLs and could lead to remote code execution.

Recommendation: Disable RMI where not required, restrict access to trusted hosts, apply Java security updates, and harden remote class-loading behavior.

VA-03 — SSL POODLE / SSLv3 Exposure

Severity: High | **CVE:** CVE-2014-3566

The assessment identified SSL POODLE exposure associated with SSLv3. Legacy protocol support can weaken the confidentiality of protected communications under appropriate conditions.

Recommendation: Disable SSLv3 and legacy cipher suites and require modern TLS configurations.

VA-04 — Weak Diffie-Hellman / Logjam

Severity: High | **CVE:** CVE-2015-4000

The scan identified export-grade Diffie-Hellman parameters and insufficient-strength DH groups, including Logjam-related exposure.

Recommendation: Remove export-grade cryptography, use strong DH parameters, disable weak cipher suites, and update affected cryptographic software.

VA-05 — Web Application Vulnerabilities / Attack Surface

Severity: High

The HTTP service exposed applications and resources including DVWA, Mutillidae, TikiWiki, phpMyAdmin, phpinfo, and TWiki-related content. Nmap also reported possible CSRF and SQL-injection findings.

Recommendation: Remove intentionally vulnerable applications from production systems, patch web software, use parameterized queries, validate input, implement CSRF protections, restrict administrative interfaces, and remove unnecessary information-disclosure files.

VA-06 — Legacy Remote Access Protocols

Severity: High | **Ports:** 23, 512, 513, 514

Telnet, rexec, rlogin, and rsh services were exposed. These legacy protocols can provide insecure remote access and increase the attack surface.

Recommendation: Disable unnecessary legacy remote-access services and use securely configured SSH instead.

5. Risk Summary

ID	Finding	Severity	Priority
VA-01	vsFTPD 2.3.4 backdoor	Critical	Immediate
VA-02	Java RMI RCE exposure	Critical	Immediate
VA-03	SSL POODLE	High	High
VA-04	Weak DH / Logjam	High	High
VA-05	Vulnerable web applications	High	High
VA-06	Legacy remote-access protocols	High	High

6. Remediation Plan

Immediate: remove the vsFTPD 2.3.4 backdoor exposure; disable or restrict Java RMI; disable Telnet, rlogin, rsh, and rexec where unnecessary.

High priority: patch or remove vulnerable web applications; modernize TLS configuration; remove weak DH/export cryptography; restrict SMB, NFS, database, and other exposed services to trusted networks.

Ongoing: maintain patch management, secure configuration baselines, host firewall controls, network segmentation, and periodic authenticated vulnerability assessments.

7. Conclusion

The assessment identifies a critical security posture for the Metasploitable VM. The target exposes many legacy services and intentionally vulnerable applications. The vsFTPD 2.3.4 backdoor is the strongest finding and was explicitly identified as exploitable with root-level command execution by the Nmap check. The findings should be treated as laboratory evidence and the VM should remain isolated from untrusted networks.

Prepared for controlled security-training/laboratory use.